

內部人員交易報表轉媒體儲存系統

決策紀錄樣板 ADR

PDF 閱讀版：含目錄與頁碼

文件來源	決策紀錄樣板ADR.md
產出位置	決策紀錄樣板ADR.pdf

目錄

內部人員交易報表轉媒體儲存系統 決策紀錄樣板 ADR	3
版本 v1.1	3
1. 文件目的	3
2. ADR 使用方式	3
3. 人類優先決策 Top 11	4
4. ADR-001 資料庫最終選型與遷移路線	5
5. ADR-002 舊系統承接、正式基準與下線策略	5
6. ADR-003 身分驗證、API 授權與 Session 生命週期	6
7. ADR-004 Golden Dataset 與正式資料使用邊界	6
8. ADR-005 權限治理模型與 Admin 職責分離	7
9. ADR-006 稽核鏈實作範圍、fail-closed 與保存落腳	7
10. ADR-007 PDF Library、Linux Container baseline 與 PDF 安全分級	8
11. ADR-008 PDF / Object Storage / WORM 儲存與保存政策	8
12. ADR-009 Validation Rule 表達、版本化與維護責任	9
13. ADR-010 第一版預算、人力、時程與 NFR 上限	9
14. ADR-011 Agent Team 自動決策、人類簽核與違規阻擋邊界	10
15. 決策狀態追蹤表	11

內部人員交易報表轉媒體儲存系統 決策紀錄樣板 ADR

版本 v1.1

1. 文件目的

本文件用於集中管理本計畫需要人類優先決策的 Top 11 關鍵點。這些決策會影響系統架構、資安邊界、權限治理、資料一致性、舊系統遷移、驗收 Gate、預算與時程，不應由工程團隊或 AI 在未授權情況下自行假設。

本文件不是功能需求清單；功能拆分以「功能里程碑計畫」為準，系統架構與治理原則以「系統架構與治理計畫書」為準。

2. ADR 使用方式

每一筆決策請至少填寫以下欄位：

欄位	說明
ADR 編號	例如 ADR-001。
決策狀態	Proposed / Accepted / Rejected / Superseded / Deferred。
決策日期	YYYY-MM-DD。
決策 owner	負責推動決策的人或單位。
參與角色	業務、稽核、資安、DBA、維運、QA、DevOps、開發、法遵等。
背景	為什麼需要決策。
候選方案	可選方案與簡要差異。
決策內容	最終選擇。
採用理由	為什麼選這個方案。
影響範圍	影響哪些模組、里程碑、資料、安全、維運或採購。
驗收 Gate	什麼條件達成才算決策落地。
待補問題	尚未釐清的問題。

3. 人類優先決策 Top 11

優先	ADR	需要人類決策的關鍵點	為何優先
1	ADR-001	資料庫最終選型與遷移路線	影響 SP 改寫、ORM、DBA 能力、備份工具鏈、稽核鏈與 M1/M9-01 是否可開工。
2	ADR-002	舊系統承接、正式基準與下線策略	影響哪些功能可沿用、封裝、重寫或淘汰，也決定 MSSQL leader 何時能下線。
3	ADR-003	身分驗證、API 授權與 Session 生命週期	影響前後端切分、下載閘道、Admin 職責分離、break-glass 與高機密二次驗證。
4	ADR-004	Golden Dataset 與正式資料使用邊界	影響測試合法性、影子比對環境、資料血緣、脫敏工具與稽核核准。
5	ADR-005	權限治理模型與 Admin 職責分離	影響 RBAC、Data Scope、角色建立、權限指派、雙人覆核與高權限風險。
6	ADR-006	稽核鏈實作範圍、fail-close d 與保存落腳	影響 M1-04、M7-01、寫入延遲、WORM/獨立 DB、稽核匯出與證據能力。
7	ADR-007	PDF Library、Linux Container baseline 與 PDF 安全分級	影響 M0-04、M3-04、M5-04、中文、浮水印、簽章、PDF/A、QR Code 與是否可下載。
8	ADR-008	PDF / Object Storage / WORM 儲存與保存政策	影響 M4-02、備份、資料主權、保存年限、下載副本是否保存與儲存成本。
9	ADR-009	Validation Rule 表達、版本化與維護責任	影響 M2-01 是否能拆任務、規則異動是否需發版、業務或稽核能否自助維護。
10	ADR-010	第一版預算、人力、時程與 NFR 上限	影響哪些 P1/P2 能延後、worker 化時機、UAT 長度、上線日期與 Go / No-Go 門檻。
11	ADR-011	Agent Team 自動決策、人類簽核與違規阻擋邊界	影響任務卡派工、reviewer、validator、human sign-off、ADR gate、違規阻擋與 closure gate。

4. ADR-001 資料庫最終選型與遷移路線

欄位	內容
決策狀態	Proposed
決策 owner	待指定：資訊主管 / DBA 主管
參與角色	DBA、開發、維運、資安、稽核、採購
候選方案	維持 MSSQL、MSSQL on Linux、PostgreSQL、MariaDB。
建議預設方向	不預設 MariaDB 一定正確。M0 PoC 比較相容性、授權、維運與效能後再定。
需回答	是否接受 MSSQL 授權延續？是否可承擔 T-SQL 逐步改寫成本？DBA 熟悉度與招募難度如何？同步方式採 CDC、ETL、Outbox 還是批次？
影響範圍	M0-04、M0-05、M1、M9-01、ORM、備份工具鏈、稽核鏈、DBA 維運。
驗收 Gate	完成 DB PoC；完成 SP / SQL 分類；列出相容性差異與改寫成本；DBA 與維運簽核。

5. ADR-002 舊系統承接、正式基準與下線策略

欄位	內容
決策狀態	Proposed
決策 owner	待指定：業務 owner / 系統 owner
參與角色	業務、稽核、DBA、開發、QA、維運
候選方案	一年內完全下線 MSSQL leader、3/6/12 個月並行、長期雙寫共存。
建議預設方向	不一次全量切換。先 Pilot 非正式或低機密報表，再分批、分部門或分報表等級切換。
需回答	並行運轉期上限？並行期間正式報表以誰為準？哪些報表、SP、view、trigger、batch job 要沿用、封裝、重寫或淘汰？
影響範圍	M0-01、M0-05、M3-04、M9-05、M10-02、授權續約、Rollback Window。
驗收 Gate	每個舊功能都有承接策略；連續 N 批次或 N 天雙製比對通過；業務、稽核、資安、維運簽核後才可下線 MSSQL leader。

6. ADR-003 身分驗證、API 授權與 Session 生命週期

欄位	內容
決策狀態	Proposed
決策 owner	待指定：資安 / 身分治理 owner
參與角色	資安、AD/SSO 管理員、開發、維運、稽核
候選方案	AD / LDAPS、ADFS / SAML、Azure AD / Entra ID、OIDC、自建 SSO；API 授權採 cookie session、JWT bearer、mTLS 或組合。
建議預設方向	優先使用公司既有 SSO；後端 API 必須重新授權；下載閘道使用短效下載授權，不直接暴露 Object Storage URL。
需回答	公司現有 SSO 是哪一套？SPA + JWT 是否可接受？cookie session 是否符合內網部署？下載 token TTL 幾分鐘？高機密下載二次驗證走同一套 SSO 還是另加 MFA？
影響範圍	M0-04、Auth Module、M5、M6、M8-03、稽核欄位、Session/Token 安全。
驗收 Gate	完成 SSO PoC；定義 token/session TTL；完成未授權、逾期、下載重放與高機密二次驗證測試。

7. ADR-004 Golden Dataset 與正式資料使用邊界

欄位	內容
決策狀態	Proposed
決策 owner	待指定：QA / 資料治理 owner
參與角色	業務、稽核、資安、QA、DBA、開發
候選方案	合成資料、脫敏資料、遮罩資料、受控 Shadow Validation Data。
建議預設方向	Golden Dataset 不含未脫敏正式資料；正式資料只可用於受控 Shadow Validation，且需隔離、權限、稽核與核准。
需回答	是否已有脫敏工具？誰核准 Golden Dataset？誰維護 expected result？Shadow Validation 是否允許使用受控正式資料？
影響範圍	M0-03、M2、M3-04、M9-02、CI/SIT、資料血緣、稽核證據。
驗收 Gate	Golden Dataset 有資料血緣、維護責任、核准紀錄與 expected result；Shadow Validation 有隔離環境與存取稽核。

8. ADR-005 權限治理模型與 Admin 職責分離

欄位	內容
決策狀態	Proposed
決策 owner	待指定：資安 / 權限治理 owner
參與角色	資安、稽核、業務主管、系統管理員、開發
候選方案	固定角色、可自訂角色、RBAC + Data Scope、ABAC 補充、雙人覆核。
建議預設方向	採 RBAC + Data Scope。Role 控制可做什麼，Data Scope 控制可看哪些資料。Admin 職責分離，Admin 不因管理權限自動取得報表內容權限。
需回答	誰可建立角色？誰可指派權限？誰可調整資料範圍？哪些權限異動需雙人覆核？自訂角色是否需到期日與定期覆核？
影響範圍	M2-04、M6、M8-01、M8-02、稽核紀錄、高機密報表授權。
驗收 Gate	完成預設 Admin 角色定義；完成角色建立/指派/Data Scope 異動稽核；完成無權限、跨部門、高機密測試。

9. ADR-006 稽核鏈實作範圍、fail-closed 與保存落腳

欄位	內容
決策狀態	Proposed
決策 owner	待指定：稽核 / 資安 owner
參與角色	稽核、資安、DBA、開發、維運
候選方案	完整 Hash Chain、分範圍鏈、週期 root hash、WORM 封存、獨立稽核 DB。
建議預設方向	第一版採核心欄位 + event_payload_json + payload_hash；關鍵操作 fail-closed；Hash Chain 採分範圍鏈或週期 root hash；一般查詢可 retry 但不得靜默遺失。
需回答	哪些操作必須 fail-closed？稽核鏈範圍依模組、報表、日期或事件類型？可接受同步寫入延遲多少？稽核 DB 是否需與業務 DB 隔離？是否需要 WORM？
影響範圍	M1-04、M7-01、資料模型、效能、告警、稽核匯出、證據保存。
驗收 Gate	完成稽核欄位字典；完成 fail-closed 清單；完成 Hash Chain/root hash 驗證；完成稽核查詢本身被稽核。

10. ADR-007 PDF Library、Linux Container baseline 與 PDF 安全分級

欄位	內容
決策狀態	Proposed
決策 owner	待指定：技術 owner / 資安 owner
參與角色	開發、資安、稽核、法遵、採購、維運
候選方案	iText、QuestPDF、Syncfusion PDF、其他商用 PDF SDK。
建議預設方向	M0/M3 前期完成 PDF Library PoC；必須支援 Linux、中文嵌入字型、逐頁浮水印、metadata、canonical text extraction、大量產生與簽章需求。
需回答	可接受年度授權預算？是否可用 AGPL？是否需要 PAdES-LTV 或 PDF/A？哪些報表代號屬一般、機密、高機密、極高機密？極高機密是否第一版就不可下載？
影響範圍	M0-04、M3-04、M5-02、M5-04、M6-02、M9-02、PDF 安全與效能。
驗收 Gate	Linux Container PDF baseline 通過；Windows 與 Linux 差異可解釋；高機密策略被稽核/業務/法遵核准；不宣稱 PDF 100% 防竄改。

11. ADR-008 PDF / Object Storage / WORM 儲存與保存政策

欄位	內容
決策狀態	Proposed
決策 owner	待指定：維運 / 儲存平台 owner
參與角色	維運、資安、法遵、DBA、開發、採購
候選方案	企業 NAS、MinIO on-prem、S3-compatible storage、公有雲 S3、企業既有物件儲存、WORM/Immutable Archive。
建議預設方向	PDF 主檔不可直接存取，下載必須經 Download Gateway。下載副本預設只保存 hash 與 metadata；若保存副本需 Security Admin 核准、加密、期限與稽核。
需回答	是否可用公有雲？保存年限是 7 年、10 年或更久？哪些資料需 WORM？Object Storage 是否支援 immutability？備份與還原窗口如何設定？
影響範圍	M4-02、M4-04、M5-03A、M9-02、DR、資料主權、成本。
驗收 Gate	完成儲存 PoC；完成權限隔離、加密、備份還原測試；完成保存年限與 WORM 需求簽核。

12. ADR-009 Validation Rule 表達、版本化與維護責任

欄位	內容
決策狀態	Proposed
決策 owner	待指定：業務規則 owner / 開發 owner
參與角色	業務、稽核、開發、QA、DBA
候選方案	JSON rule、SQL view + version metadata、C# strategy class、scripted predicate、外掛 DSL。
建議預設方向	第一版避免過度設計 DSL。優先採可版本化、可稽核、可測試的簡單模型；高風險或複雜規則可先由開發維護，常變動規則再評估自助維護。
需回答	規則異動由業務/稽核自助還是開發發版？規則是否需要模擬執行？規則版本如何與報表 Snapshot 綁定？
影響範圍	M2-01、M2-02、M2-03、M3 Snapshot、Golden Dataset expected result。
驗收 Gate	規則異動有版本、生效時間、異動原因與稽核；Golden Dataset 可驗證 Pass / Warning / Error / Critical 結果。

13. ADR-010 第一版預算、人力、時程與 NFR 上限

欄位	內容
決策狀態	Proposed
決策 owner	待指定：專案 sponsor / PM
參與角色	業務 sponsor、PM、開發、DBA、資安、QA、DevOps、維運、稽核
候選方案	保守 MVP、完整第一版、分兩階段上線、先 Pilot 後正式擴大。
建議預設方向	保守 MVP + Pilot。第一版聚焦安全、權限、稽核、資料一致性、可回復；PAM/session recording、完整 WORM、搜尋平台、Kubernetes、全公司框架可延後。
需回答	目標上線日期？後端、DBA、資安、QA、DevOps 人力配置？預算天花板？NFR 門檻如何量化？哪些功能可延後到 Level 2？
影響範圍	全部 M0-M10、P0/P1/P2 排程、採購、UAT、訓練、Go / No-Go Gate。
驗收 Gate	核准專案時程、人力與預算；核准 NFR 基準；核准第一版不得做與可延後清單。

14. ADR-011 Agent Team 自動決策、人類簽核與違規阻擋邊界

欄位	內容
決策狀態	Proposed
決策 owner	待指定：專案 sponsor / 資安 owner / 稽核 owner / Tech Lead
參與角色	PM、Tech Lead、資安、稽核、QA、DevOps、系統 owner、Agent Team Captain
候選方案	低風險事項由隊長 AI 自動決定、所有事項皆人工簽核、依風險分級自動化、導入 runtime permission broker / sandbox。
建議預設方向	採風險分級。隊長 AI 可自動處理低風險、可回復、已有規則的執行決策；資安、稽核、資料、正式切換、權限模型、供應商與架構取舍需人類或 ADR 簽核。
需回答	哪些任務卡必須 human sign-off？哪些工具或網路存取需限制？Permission Broker、lease/fencing、tool sandbox 第一版落地到什麼程度？若 Agent 自動決策與資安/稽核衝突，由誰裁決？
影響範圍	全部 TASK-RPT 任務卡、M5、M7、M8、M9、closure gate、CI scope check、review 流程與證據保存。
驗收 Gate	Agent Team 計畫書 v1.0 已核准；任務卡已標示 agent_team_plan、reviewer、validator、human/ADR gate；違規阻擋機制與人工補位流程已被資安與稽核接受。

15. 決策狀態追蹤表

ADR	決策狀態	Owner	目標決策時間	目前結論	待補問題
ADR-001	Proposed	待指定	M0 結束前	未決	DB PoC 結果、授權、DBA 能力。
ADR-002	Proposed	待指定	M0 結束前	未決	並行期、正式報表基準、下線 Gate。
ADR-003	Proposed	待指定	M0-04 PoC 前	未決	SSO、token、下載 TTL、MFA。
ADR-004	Proposed	待指定	M0-03 完成前	未決	脫敏工具、資料核准、維護責任。
ADR-005	Proposed	待指定	M2-04 前	未決	Admin 分工、雙人覆核、Data Scope owner。
ADR-006	Proposed	待指定	M1-04 前	未決	fail-closed、Hash Chain 範圍、WORM。
ADR-007	Proposed	待指定	M0-04 / M3-04 前	未決	PDF SDK、授權、PAdES-LTV、機密分級。
ADR-008	Proposed	待指定	M4-02 前	未決	NAS/Object Storage、WORM、保存年限。
ADR-009	Proposed	待指定	M2-01 前	未決	規則表達、版本化、維護責任。
ADR-010	Proposed	待指定	專案啟動前	未決	上線日期、人力、預算、NFR。
ADR-011	Proposed	待指定	任務卡正式派工前	未決	Agent 自動決策範圍、human/ADR gate、違規阻擋與 closure gate。